

Gap platformasi — Texnik topshiriq (TZ)

2026-09-19

@Someone

1. Umumiy ma'lumot

Gap platformasi — an'anaviy "gap" (davra jamg'armasi) o'yinini raqamlashtiradigan web-tizim: a'zolar har oy belgilangan summani to'laydi, yig'ilgan pul navbat bo'yicha bitta a'zoga beriladi.

Muammo. Hozir gap'lar qog'ozda yoki Telegram guruhlarda yuritiladi: kim to'ladi-to'lamadi aniq emas, navbat bahsli, tarix yo'qoladi, hisob-kitob bir odamning xotirasiga bog'liq.

Yechim. Har bir davra uchun shaffof raqamli hisob: to'lovlar avtomatik qayd etiladi, navbat oldindan kelishilgan qoidaga bo'ysunadi, har bir a'zo istalgan payt o'z holatini ko'radi.

Loyiha maqsadi:

- Davra pulini boshqarishni ishonchli va shaffof qilish
- To'lovlarni Payme/Click orqali avtomatlashtirish
- Nizoli holatlarni (kim to'lamadi, navbat kimniki) tizim darajasida hal qilish
- Texnologiyadan uzoq foydalanuvchi ham 2–3 bosqichda ishlata oladigan qulaylik

MVP doirasiga kirmaydi: pulni platforma ichida saqlash (litsenziya talab qiladi), kredit berish, valyuta operatsiyalari. Platforma pul oqimini *qayd etadi va boshqaradi*, lekin o'zi bank emas.

2. Foydalanuvchi rollari

Rol	Kim	Huquqlari
Mehmon	Ro'yxatdan o'tmagan	Landing, taklif havolasi orqali davra haqida qisqa ma'lumot ko'rish
A'zo	Davraga qo'shilgan foydalanuvchi	O'z to'lovlari, davra holati, navbat, tarix, bildirishnomalar
Tashkilotchi	Davrani yaratgan a'zo	Davra sozlamalari, a'zolarni taklif qilish/chiqarish, qo'lda to'lov qayd etish, navbatni boshqarish
Platforma admini	Tizim egasi	Foydalanuvchilar, davralar monitoringi, shikoyatlar, bloklash, audit log

Bitta foydalanuvchi bir vaqtda bir nechta davrada turli rollarda bo'la oladi: bittasida tashkilotchi, boshqasida oddiy a'zo. Rol davra darajasida saqlanadi, tizim darajasida emas.

3. Funktsional talablar

3.1. Ro'yxatdan o'tish va kirish

- Telefon raqami + SMS kod orqali ro'yxatdan o'tish (O'zbekistonda eng tanish usul)
- Parol o'rnatish; qaytadan kirishda telefon + parol, istalganda SMS orqali tiklash
- Profil: ism, familiya, avatar (ixtiyoriy)
- Sessiyalar ro'yxati: qaysi qurilmalardan kirilgan, istalganini uzish

3.2. Davra yaratish va sozlash

Tashkilotchi davra yaratadi va quyidagilarni belgilaydi:

- Nomi va tavsifi
- Oylik badal summasi (UZS; bazada tiyin hisobida, BIGINT)
- A'zolar soni (masalan, 10–12 kishi) — davra muddati shundan kelib chiqadi
- To'lov sanasi va to'lov muhlati (deadline)
- Navbat qoidasi: qur'a (tizim tasodifiy aralashtiradi), kelishuv (tashkilotchi qo'lda tartiblaydi) yoki ariza (ehtiyoji borlar oldinroq so'raydi, ovoz berish bilan)
- Qisman to'lovga ruxsat (ha/yo'q) va raund yopilish qoidasi: barcha majburiyatlar to'liq to'langanda yoki oldindan belgilangan fallback qoida bo'yicha
- Jarima qoidasi (yoqilsa): imtiyoz muddati (grace period), foiz yoki qat'iy summa, maksimal chegara, qachon hisoblanishi
- Chiqish siyosati (exit policy): qolganlar bilan davom etish, o'rinbosar topish yoki qayta hisoblash — har birining moliyaviy natijasi shartlarda oldindan yoziladi

Davra holatlari: Yig'ilmoqda → Faol → Yakunlangan (yoki Bekor qilingan). Davra barcha a'zolar to'planib, hamma navbat qoidasini tasdiqlagandan keyingina faollashadi.

3.3. A'zolari taklif qilish

- Har bir taklif alohida yozuv (invitation): kod/token, amal qilish muddati, ishlatilish limiti, holati, kim qabul qilgani
- Qabul qilishda a'zo davra shartlarini (summa, muddat, navbat qoidasi, jarima, exit policy) ko'radi; rozilik alohida consent yozuvida saqlanadi: foydalanuvchi, davra, shartlar versiyasi, sana/vaqt, IP va qurilma
- Davra faollashgach yangi a'zo qo'shilmaydi; chiqish faqat exit policy bo'yicha (3.9-band)

3.4. To'lovlar

To'lov ikki qatlamda modellashtiriladi — *majburiyat* (obligation) va *real tranzaksiya* alohida:

- Har raund ochilganda har bir faol a'zo uchun to'lov majburiyati avtomatik yaratiladi (scheduler); majburiyat holatlari: `PENDING` → `PARTIALLY_PAID` → `PAID` / `OVERDUE`
- Real to'lovlar alohida tranzaksiya yozuvlari sifatida saqlanadi — shu tufayli 1 000 000 so'mlik majburiyatni 400 000 + 600 000 qilib bo'lib to'lash mumkin (qisman to'lov yoqilgan bo'lsa)
- Tranzaksiya maydonlari: usul (Payme/Click/naqd), provider, provider tranzaksiya ID, idempotency key, holat, sanalar
- Naqd to'lovni tashkilotchi qayd etadi, to'lovchi tasdiqlaydi (ikki tomonlama tasdiq); qo'lda qayd ham idempotent — takror bosishda ikkinchi yozuv tushmaydi
- `OVERDUE` holatini muhlat o'tganda scheduler belgilaydi; jarima (yoqilsa) alohida moliyaviy yozuv sifatida hisoblanadi
- Eslatmalar: muhlatdan 3 kun oldin va muhlat kuni (scheduler orqali)
- Raund yopilganda oluvchiga berish alohida payout yozuvi: kim qayd etdi, qachon, qanday usulda; oluvchi SMS tasdiq bilan "pulni oldim" deb tasdiqlaydi

3.5. Navbat va davra hayoti

- Har bir a'zo ko'radi: kim nechanchi, men nechanchiman, qachon olaman, oyma-oy jadval
- Qur'a natijasi audit qilinadi: tasodifiy natija (seed), ishtirokchilar ro'yxati va yakuniy tartib saqlanadi — keyinchalik "adolatli bo'lganini" isbotlash mumkin
- Navbatni almashtirish faqat davra qoidalarida ruxsat etilgan bo'lsa: ikki a'zo o'zaro tasdiqlaydi, eski va yangi tartib `queue_changes` tarixida qoladi
- Har oy raund sifatida yopiladi: kim to'ladi, kim kechikdi, kim oldi — yopilgan raund yozuvlari o'zgarmas

3.6. Bildirishnomalar

- Kanallar: Telegram bot (asosiy), SMS (muhim hodisalar), email (ixtiyoriy)
- Hodisalar: to'lov eslatmasi, to'lov qabul qilindi, sizning navbatingiz keldi, a'zo kechikdi (tashkilotchiga), davra holati o'zgardi

3.7. Hisobotlar va tarix

- Davra bo'yicha to'liq moliyaviy tarix: har bir to'lov, sana, usul, kim tasdiqlagan
- A'zoning shaxsiy hisoboti: qancha to'ladim, qancha oldim, qaysi davralarda qatnashganman
- PDF ko'chirma (davra yakunida yoki istalgan payt)

3.8. Nizolar va shikoyat

- A'zo istalgan to'lov yozuviga e'tiroz bildiradi — yozuv **Bahsli** holatiga o'tadi, tashkilotchi izoh bilan hal qiladi
- Hal bo'lmasa, platforma adminiga shikoyat; admin faqat tarixni ko'radi va tavsiya beradi, pulga aralashmaydi

3.9. A'zolik hayot sikli

- A'zolik holatlari: **ACTIVE** → **LEFT** (o'zi chiqdi) / **REMOVED** (chiqarildi); chiqqan a'zoning to'lov tarixi hech qachon o'chirilmaydi
- Chiqish davra yaratilishida tanlangan exit policy bo'yicha: qolganlar bilan davom etish, o'rinbosar topish yoki summani qayta hisoblash
- Davra bekor qilinsa: yig'ilgan, hali berilmagan mablag'lar to'lovchilarga qaytarilishi storno yozuvlari bilan qayd etiladi

4. Xavfsizlik talablari

Pul bilan ishlaydigan tizim uchun xavfsizlik alohida bo'lim sifatida majburiy.

4.1. Autentifikatsiya va sessiyalar

- Parollar faqat argon2/bcrypt bilan xeshlanadi, hech qachon ochiq saqlanmaydi
- JWT access token (15 daqiqa) + refresh token (httpOnly cookie, har yangilanishda rotatsiya); har bir sessiya alohida yozuv: qurilma, IP, token xeshi, muddati, bekor qilingan vaqti — foydalanuvchi sessiyalarini ko'radi va istalganini uzadi
- Login urinishlari limiti: 5 marta xato → 15 daqiqa bloklash; SMS kod so'rash limiti: raqam boshiga soatiga 3 ta
- Pul bilan bog'liq amallar (payout tasdig'i, navbat almashtirish) qo'shimcha SMS tasdiq talab qiladi

4.2. Pul operatsiyalari yaxlitligi

- Har qanday moliyaviy yozuv faqat DB tranzaksiyasi ichida, atomik yoziladi; raundning yig'ilgan summasi **SELECT ... FOR UPDATE** yoki atomik increment bilan yangilanadi — parallel kelgan webhook'lar poyga holati (race condition) tug'dirmasligi uchun
- Idempotency: **idempotency_key** **UNIQUE** hamda **provider + provider_transaction_id** **UNIQUE** — takror webhook ikkinchi moliyaviy natija hosil qilmaydi

- To'lov yozuvlari o'zgarmas (immutable): tahrirlash yo'q, bekor qilish faqat storno yozuvi bilan (`reversal_of_id`); stornoni faqat tashkilotchi ochadi, sababi majburiy, hammasi audit log'da
- Jarima ham alohida moliyaviy yozuv — obligation summasini "tahrirlash" emas
- Audit log'ning o'zi ham append-only: kim, qachon, nima qildi, qaysi IP'dan — o'chirilmaydi

4.3. Ma'lumotlar himoyasi

- Hamma joyda HTTPS; HSTS yoqilgan
- Telefon raqamlari boshqa a'zolarga qisman ko'rsatiladi (+998 90 *** ** 45), to'liq raqam faqat tashkilotchiga
- O'zbekiston "Shaxsiy ma'lumotlar to'g'risida"gi qonuni: fuqarolarning shaxsiy ma'lumotlari O'zbekiston hududidagi serverda saqlanishi talab etiladi — hosting tanlashda hisobga olinadi; xorijiy VPS ishlatilsa, ishga tushirishdan oldin huquqiy tekshiruv shart
- Barcha sana/vaqlar bazada UTC'da saqlanadi, interfeys Asia/Tashkent bo'yicha ko'rsatadi; to'lov sanasi va muhlatlar ham shu zona bo'yicha hisoblanadi
- SQL injection — faqat ORM/parametrlangan so'rovlar; XSS — kiritmalar sanitizatsiyasi; CSRF — token bilan
- API rate limiting (umumiy va endpoint darajasida)
- Backup: DB kunlik zaxira, 30 kun saqlanadi, alohida serverda; tiklash (restore) har chorakda amaliy sinovdan o'tkaziladi

4.4. Ijtimoiy xavflar (fraud)

- Eng katta xavf texnik emas, ijtimoiy: birinchi bo'lib pul olgan a'zo keyin to'lamay qo'yishi. Tizim buni butunlay yo'qota olmaydi, lekin kamaytiradi:
 - Ishonch reytingi aniq formula bilan: o'z vaqtida to'lovlar ulushi (70%), yakunlangan davralar soni (20%), asosli e'tirozlar (10%) — har raund yopilganda qayta hisoblanadi va yangi davraga qo'shilishda ko'rinadi
 - Navbatda oxirgi o'rinlar yangi (tarixsiz) a'zolarga berilishi tavsiya etiladi
 - To'lamagan a'zo profili barcha davralarida belgilanadi
- A'zo chiqib ketishi va davra bekor bo'lishi holatlari 3.9-banddagi exit policy va storno qoidalari bilan qoplanadi — hech bir stsensariy "kelishib olamiz"ga qoldirilmaydi

5. UX va qulaylik tamoyillari

Asosiy auditoriya — texnologiyadan uzoq bo'lishi mumkin bo'lgan oddiy foydalanuvchilar. Shunga mos qoidalar:

- **Til:** interfeys o'zbek (lotin) tilida, rus tili qo'shimcha; atamalar xalq tilida — "badal", "navbat", "davra", bank jargoni emas
- **Mobil-birinchi:** foydalanishning 90%+ qismi telefondan bo'ladi; hamma sahifa telefonda bir qo'lda ishlatiladigan qilib chiziladi (PWA — bosh ekranga o'rnatiladi, ilova kabi ochiladi)
- **Bosh ekran = bitta savol javobi:** "Men qachon to'layman va qachon olaman?" — kirgan zahoti keyingi to'lov sanasi, summasi va navbati ko'rinadi
- **3 bosqich qoidasi:** har qanday asosiy amal (to'lash, davraga qo'shilish) maksimum 3 bosqichda
- **Raqamlar o'qiladigan formatda:** 1 200 000 so'm, sanalar "15-oktabr" ko'rinishida
- **Holatlar rang bilan:** to'langan — yashil, kutilmoqda — sariq, kechikkan — qizil; faqat rangga tayanmasdan, yozuv bilan birga
- **Telegram bot** — kirish nuqtasi sifatida ham: bot orqali holatni ko'rish va eslatma olish, saytga faqat murakkab amallar uchun o'tiladi
- Sekin internet uchun yengil sahifalar (< 300 KB birinchi yuklanish)

6. Nofunksional talablar

Talab	Ko'rsatkich
Javob tezligi	API 95% so'rovlarda < 300 ms
Bir vaqtda foydalanuvchi	MVP: 1 000; arxitektura 50 000 gacha kengayadigan
Ishlash barqarorligi	99.5% uptime; to'lov webhook'lari navbat (queue) orqali, yo'qolmaydi
Brauzerlar	Chrome, Safari, Samsung Internet — oxirgi 2 versiya
Zaxira	DB kunlik backup, 30 kun saqlanadi; tiklash rejasi hujjatlashtirilgan
Monitoring	Xatolar (Sentry), server metrikalari, to'lov xatolari uchun alert

7. Texnologiyalar to'plami

Qatlam	Texnologiya	Izoh
Backend	NestJS (TypeScript)	Modulli arxitektura, sizga tanish stack
Ma'lumotlar bazasi	PostgreSQL 16	Pul operatsiyalari uchun ACID tranzaksiyalar shart
ORM	Prisma	Migratsiyalar va tip xavfsizligi
Navbat (queue)	BullMQ + Redis	Webhook'lar, SMS/bildirishnoma yuborish, kechikish tekshiruvi (cron)
Frontend	Next.js + Tailwind	SSR — sekin internetda tez ochiladi, PWA qo'llab-quvvatlaydi
To'lov	Payme + Click API	Payme integratsiyasida tajribangiz bor
Bildirishnoma	Telegram Bot API, Eskiz.uz (SMS)	Eskiz — O'zbekistonda SMS shlyuz
Hosting	VPS (Contabo) + Docker Compose	Nginx reverse proxy, Let's Encrypt SSL
Monitoring	Sentry + Uptime Kuma	Xatolar va uptime kuzatuv

8. Ma'lumotlar bazasi sxemasi

Asosiy jadvallar va bog'lanishlar:

```

flowchart TD
    U[users] --> S[sessions]
    U --> M[memberships]
    C[circles] --> M
    C --> I[invitations]
    C --> CS[circle_consent]
    C --> R[rounds]
    R --> PO[payment_obligations]
    PO --> PT[payment_transactions]
    R --> PY[payouts]
    PT --> D[disputes]
    PY --> D
  
```

O'qilishi: foydalanuvchilar a'zolik orqali davralarga bog'lanadi; davra oylik raundlarga bo'linadi; har raundda a'zolar uchun to'lov majburiyatlari ochiladi, ular real tranzaksiyalar bilan yopiladi va oluvchiga payout bilan yakunlanadi; e'tirozlar tranzaksiya yoki payout'ga bog'lanadi. To'liq jadvallar ro'yxati:

Jadval	Asosiy maydonlar
users	id, phone, password_hash, name, surname, avatar_url, trust_score, created_at
sessions	id, user_id, token_hash, device_info, ip, expires_at, last_used_at, revoked_at
circles	id, name, description, amount, member_count, pay_day, queue_rule, penalty_rule, partial_payment_allowed, exit_policy, status, created_by
memberships	id, user_id, circle_id, role, status, queue_position, joined_at, left_at
circle_consent	id, circle_id, user_id, terms_version, accepted_at, ip, device
invitations	id, circle_id, created_by, code, expires_at, max_uses, status, accepted_by, accepted_at
rounds	id, circle_id, round_number, period, recipient_id, required_amount, collected_amount, payment_deadline, status, closed_at
payment_obligations	id, round_id, payer_id, required_amount, paid_amount, status, due_at
payment_transactions	id, obligation_id, payer_id, amount, method, provider, provider_transaction_id, idempotency_key, status, created_at, paid_at, reversal_of_id
payouts	id, round_id, recipient_id, amount, method, status, initiated_at, completed_at, confirmed_at, recorded_by
disputes	id, circle_id, round_id, payment_id/payout_id, opened_by, reason, status, resolution, resolved_by, resolved_at

Jadval	Asosiy maydonlar
notifications	id, user_id, event, channel, status, attempts, provider_message_id, scheduled_at, sent_at, error
queue_changes	id, circle_id, type, initiated_by, old_order, new_order, status, created_at
audit_logs	id, user_id, action, entity, entity_id, metadata, ip, created_at

Muhim cheklovlar (constraints):

- `payment_transactions.idempotency_key` — UNIQUE; `(provider, provider_transaction_id)` — UNIQUE: bitta to'lov takror yozilmaydi
- `memberships (user_id, circle_id)` — UNIQUE: bir davraga ikki marta qo'shilib bo'lmaydi
- `rounds (circle_id, round_number)` — UNIQUE: raundlar takrorlanmaydi
- Barcha summalar `BIGINT` (tiyin hisobida) — `FLOAT` hech qachon ishlatilmaydi
- Moliyaviy jadvallarga (`payment_transactions`, `payouts`) `UPDATE` / `DELETE` yo'q — faqat `INSERT`; bekor qilish `reversal_of_id` orqali yangi yozuv
- Dispute holatlari: `OPEN` → `UNDER_REVIEW` → `RESOLVED` / `REJECTED`; obligation holatlari 3.4-bandda

9. API asosiy endpointlari

Metod	Endpoint	Vazifasi
POST	<code>/auth/register</code>	Telefon + SMS kod orqali ro'yxatdan o'tish
POST	<code>/auth/login</code>	Kirish, token olish
POST	<code>/auth/refresh</code>	Refresh token rotatsiyasi
POST	<code>/auth/logout</code>	Joriy sessiyani bekor qilish
GET	<code>/auth/sessions</code>	Sessiyalar ro'yxati
DELETE	<code>/auth/sessions/:id</code>	Sessiyani uzish
POST	<code>/circles</code>	Davra yaratish
GET	<code>/circles/:id</code>	Davra tafsilotlari (a'zolar, navbat, holat)
POST	<code>/circles/:id/invitations</code>	Taklif havolasi/kod yaratish

Metod	Endpoint	Vazifasi
POST	/circles/join	Kod orqali qo'shilish (consent qaydi bilan)
POST	/circles/:id/activate	Davrani faollashtirish (tashkilotchi)
GET	/circles/:id/rounds	Raundlar va jadval
GET	/rounds/:id	Raund tafsilotlari
POST	/payments/initiate	Payme/Click to'lovini boshlash
POST	/payments/manual	Naqd to'lovni qayd etish (tashkilotchi, idempotent)
POST	/payments/webhook/payme	Payme webhook (imzo tekshiruvi bilan)
POST	/payments/webhook/click	Click webhook (imzo tekshiruvi bilan)
POST	/payouts/:id/confirm	"Pulni oldim" tasdig'i (oluvchi, SMS bilan)
POST	/disputes	To'lov yoki payout'ga e'tiroz ochish
GET	/me/summary	Bosh ekran: keyingi to'lov, navbatim, davralarim
GET	/me/history	Shaxsiy moliyaviy tarix, PDF eksport

Hamma endpoint (auth'dan tashqari) JWT talab qiladi; rol tekshiruvi guard darajasida (davra a'zosimi, tashkilotchimi). Webhook'lar imzo (signature) tekshiruvidan o'tmasa rad etiladi.

10. MVP va bosqichma-bosqich reja

Bosqich	Muddat (taxminiy)	Nima kiradi
1. MVP	5–6 hafta	Auth + sessiyalar, davra yaratish, taklif + consent, navbat (qur'a, audit bilan), raund/obligation modeli, qo'lda to'lov qaydi, payout + tasdiq, audit log, Telegram bildirishnoma, bosh ekran
2. To'lovlar	3–4 hafta	Payme/Click integratsiyasi, webhook + idempotency, qisman to'lov, OVERDUE + jarima, PDF ko'chirma
3. Ishonch	2–3 hafta	Ishonch reytingi, dispute moduli, navbat almashtirish, admin panel

Bosqich	Muddat (taxminiy)	Nima kiradi
4. Sayqal	2 hafta	PWA, rus tili, monitoring, yuklama testlari, xavfsizlik auditi

MVP qoidasi: 1-bosqich tugagach tizim real bitta davrada (o'zingizning tanish davrangizda) sinovdan o'tkaziladi — Payme'siz, qo'lda qayd bilan. Real foydalanish 2-bosqich talablarini aniqlashtiradi.

Qabul mezon (Definition of Done): har bosqich yakunida barcha pul oqimlari uchun integratsion testlar, tranzaksiya/rollback testlari, takroriy webhook (duplicate) testi, ruxsatlarni tekshirish (authorization) testlari yozilgan; audit log ishlaydi; backup yaratish bilan birga restore amaliy sinovdan o'tkazilgan bo'lishi kerak.

11. Ochiq savollar

Boshlashdan oldin hal qilinishi kerak bo'lgan qarorlar:

- ☐ Payout'ni platforma o'zi amalga oshiradimi yoki faqat tashkilotchi qayd etadimi? (litsenziya masalasiga bevosita bog'liq)
- ☐ Jarima formulasi: foiz yoki qat'iy summa, maksimal chegara
- ☐ Qisman to'lov qoidasi va raund yopilishining fallback sharti
- ☐ Exit policy'ning qaysi varianti standart bo'ladi
- ☐ Naqd to'lov doimiy qoladimi yoki faqat MVP uchunmi?
- ☐ Platforma daromadi: davra boshiga oylik obuna, bepul + premium, yoki hozircha daromadsiz portfolio?
- ☐ Payme/Click merchant modeli: yuridik shaxs kimning nomida, shartnoma turi
- ☐ Domen va brend nomi (gap.uz band bo'lsa, muqobillar)